

CCY2001: Introduction to Cybersecurity

Week 11 — Risk Management in Cybersecurity

Dr. Hany Elshall

CCIT

April 27, 2026

Outline

- 1 Understanding Cyber Risk
- 2 Cybersecurity Risk Management
- 3 Phase 1 – Risk Identification
- 4 Phase 2 – Risk Assessment
- 5 Standards & Regulations
- 6 Phase 3 – Risk Treatment
- 7 Phase 4 – Continuous Monitoring

What is Risk in Cybersecurity?

Definition

Cyber risk is the potential for harm or loss resulting from threats exploiting vulnerabilities in digital systems, data, or processes.

Risk has **two dimensions**:

- **Likelihood** – how probable is the event?
- **Impact** – what damage would it cause?

Risk affects all three **CIA** properties:

- **Confidentiality**
- **Integrity**
- **Availability**

Key Formula

$$\text{Risk} = \text{Probability} \times \text{Impact}$$

Key Components of Cyber Risk

Threats

Events that could harm digital assets:

- Malicious actors (hackers, insiders)
- Human error
- System misconfigurations

Vulnerabilities

Weaknesses that threats can exploit:

- Unpatched software
- Weak or reused passwords
- Open or misconfigured ports

Impact

Negative consequences if exploited:

- Financial loss
- Data theft / exposure
- Operational downtime
- Reputational damage

Remember

A **risk** only exists when a *threat* and a *vulnerability* overlap and an *asset* is at stake.

Key Definitions

Term	Definition
Asset	Anything of value to an organisation: data, systems, people, or processes.
Threat	A potential event or action that could cause harm to an asset.
Vulnerability	A weakness that a threat can exploit (e.g. unpatched software).
Risk	The likelihood of a threat exploiting a vulnerability $\times$ the resulting impact.
Control	A safeguard or countermeasure used to reduce risk (e.g. firewall, MFA).
Residual Risk	The risk that remains <i>after</i> controls have been applied.
Risk Appetite	The level of risk an organisation is willing to accept.

Common Examples of Cyber Risk

- **Data breaches** from weak access control
- **Ransomware** exploiting outdated systems
- **Unauthorised access** via stolen credentials
- **Phishing** leading to credential theft
- **Malware** from untrusted downloads
- **Known-CVE exploits** on unpatched software
- **Insider misuse** (intentional or accidental)
- **DoS/DDoS** causing service unavailability

Notice the pattern

Every example maps to a **Threat** → **Vulnerability** → **Impact** chain.

What is Cybersecurity Risk Management?

Definition

The **continuous process** of identifying, assessing, and mitigating risks to an organization's IT infrastructure and information assets.

- No program can *eliminate* all risks – they are numerous and often unpredictable.
- Focus is placed on the **most critical risks** identified.
- The primary goal is to **proactively reduce** the likelihood and impact of major threats.

Important distinction!

The goal is **risk reduction**, not risk elimination. Some residual risk will always remain.

Why Does it Matter?

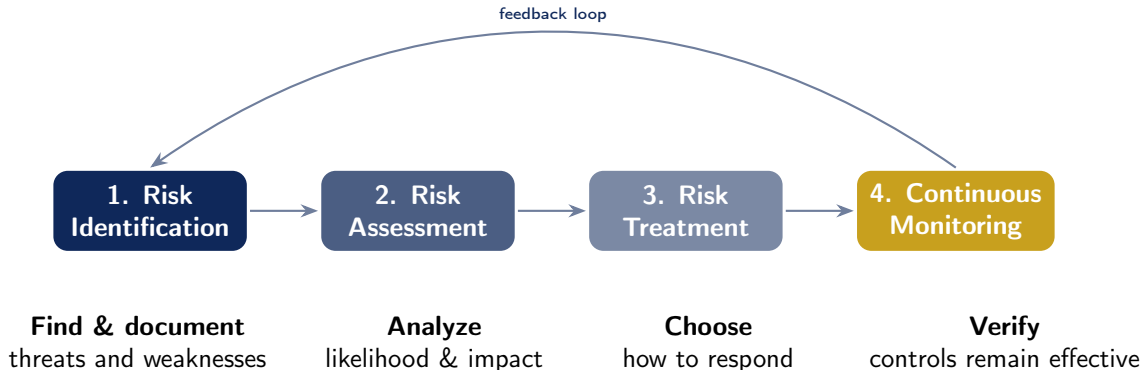
Effective risk management enables organizations to:

- Assess their current cybersecurity **risk profile**
- Make **informed decisions** to reduce risk
- **Prioritize** security actions and investments
- Enhance **situational awareness** across the team

Analysts can...

- Identify **relevant** security information
- Distinguish **critical** risks from minor ones
- **Respond** effectively to active threats

The Four Pillars of Risk Management



Phase 1: Risk Identification

Goal

Find and document all threats and vulnerabilities that could harm the organisation's digital assets *before* they are exploited.

Three key activities:

- ➊ **Asset Inventory** – catalogue all hardware, software, network devices, and data; determine which are most critical.
- ➋ **Vulnerability Discovery** – examine each asset for weaknesses: misconfigurations, outdated software, insecure access points.
- ➌ **Attack Vector Mapping** – determine how an attacker could gain access (unpatched systems, weak passwords, open ports, exposed services).

Risk sources may be **internal** (operations, staff) or **external** (market changes, regulations, natural disasters).

Phase 2: Risk Assessment

Goal

Analyze identified risks based on **likelihood of occurrence** and **severity of impact** to prioritize the organization's response.

Three assessment approaches:

Qualitative

Uses expert judgement, interviews, or workshops.

Example: Phishing rated "High" risk.

Quantitative

Uses numerical data to estimate probability and financial impact.

Example: 20% chance, \$500K impact.

Hybrid

Combines both: qualitative identification with quantitative measurement.

Risk Assessment: Steps

- 1 Identify threats and threat agents
- 2 Prioritise threats by potential impact
- 3 Assess **vulnerabilities** in the current security plan
- 4 Calculate risk for each threat:

Basic Risk Formula

$R = P \times I$ where P = Probability of threat I = Impact on the organisation

Extended Risk Formula

$$R = (P \times V) - M + U$$

P = Probability V = Asset Value M = Mitigation by controls U = Uncertainty

The Extended Risk Formula – Explained

Variable	Name	Meaning	Scale
<i>P</i>	Probability	How likely is the threat to occur?	1 (Rare) – 5 (Almost Certain)
<i>V</i>	Asset Value	How important is the asset?	1 (Low) – 5 (High)
<i>M</i>	Mitigation	How effective are existing controls?	0 (None) – 5 (Strong)
<i>U</i>	Uncertainty	How much is still unknown?	1 (Low) – 5 (High)

Insight

The extended formula provides a **more realistic** view of actual risk exposure by accounting for the effectiveness of current controls and unknowns in the threat landscape.

Risk Assessment Matrix

A **risk matrix** visually maps Probability vs Impact to produce a risk score – helping decide if action is needed.

	1 Rare	2 Unlikely	3 Possible	4 Likely	5 Almost
5 Severe	Med	High	High	Crit	Crit
4 Major	Med	Med	High	High	Crit
3 Moderate	Low	Med	Med	High	High
2 Minor	Low	Low	Med	Med	High
1 Low	Low	Low	Low	Med	Med

Impact ↓ Probability →

Low

Medium

High

Critical

Key Cybersecurity Standards & Regulations

Standards provide the **framework, methodology, and categories** needed to perform the risk management process accurately.

Standard	Purpose
ISO 27001	International standard for Information Security Management Systems (ISMS).
NIST CSF	U.S. guidelines for identifying, assessing, and managing cyber risks.
PCI DSS	Protects payment card data; applies to all card-handling organisations.
HIPAA	U.S. regulation protecting patient health information.
GDPR	EU regulation requiring consent, data protection, and breach notification.

Standards are not just *remediation roadmaps* – they guide **identification** and **assessment** phases too.

Phase 3: Risk Treatment

Goal

Choose how to **respond** to each identified risk based on the organisation's risk tolerance and available resources.

Avoidance

Eliminate the risky activity entirely.
e.g. stop storing sensitive data that isn't needed.

Reduction (Mitigation)

Add controls to lower likelihood or impact.
e.g. firewalls, MFA, patching, training.

Transfer (Sharing)

Shift risk to a third party.
e.g. cyber insurance, outsourcing.

Acceptance

Formally acknowledge the risk when mitigation cost exceeds impact.
Must be documented with a risk acceptance form.

Phase 4: Continuous Monitoring

Goal

Ensure security controls remain effective, detect new risks early, and keep risk levels within acceptable limits – *on an ongoing basis*.

- Monitor that controls are **working as intended**
- Track changes in systems, networks, and users
- Continuously scan for **new vulnerabilities**
- Review **logs, alerts**, and incident reports
- Reassess likelihood and impact as **conditions change**
- Verify **compliance** with policies and standards
- Report risk posture to **management** regularly

The Feedback Loop

Monitoring findings feed directly back into **Risk Identification**, making the process a continuous cycle, not a one-time activity.

Case Study 1 – Hospital Risk Assessment

Scenario: A medium-sized hospital is assessing risks to its patient records, scheduling, and billing systems.

Risk	Asset	Probability	Impact
Phishing Attack	Patient database	4 (Likely)	4 (Major)
Ransomware Attack	Scheduling system	3 (Possible)	5 (Severe)
Unauthorised Physical Access	On-site servers	2 (Unlikely)	3 (Moderate)

Questions to answer:

- 1 Determine the **risk level** for each risk using the matrix.
- 2 Rank the risks from **highest to lowest** priority.
- 3 Identify the most affected **CIA component** for each.
- 4 Suggest an appropriate **risk treatment** option for each.

Case Study 1 – Solution

1) Risk classification:

- Phishing (P=4, I=4) → **High**
- Ransomware (P=3, I=5) → **High**
- Physical Access (P=2, I=3) → **Medium**

2) Priority ranking:

- 1 Ransomware (*impact is higher*)
- 2 Phishing
- 3 Unauthorised Physical Access

3) CIA component affected:

- Phishing → **Confidentiality**
- Ransomware → **Availability**
- Physical Access → **C & I**

4) Risk treatment:

- Phishing: training + email filtering
- Ransomware: patching + backups
- Physical: stronger access controls

Case Study 2 – Online Retail Company

Scenario: An online retailer stores customer payment data. Management is concerned about phishing leading to credential theft.

Key information:

- Asset: Customer payment database
- Threat: Phishing emails
- Vulnerability: No security awareness training
- Impact: Data breach & financial loss

Given Data

- Estimated probability of phishing success: **30%/year**
- Estimated financial impact: **\$200,000**

Questions:

- 1 Calculate the **annual risk value**.
- 2 Suggest **risk mitigation controls**.
- 3 Explain how **continuous monitoring** reduces this risk.
- 4 Name a **relevant compliance standard**.

Case Study 2 – Solution

1) Annual Risk Value:

$$R = P \times I = 0.30 \times \$200,000 = \$60,000/\text{year}$$

2) Mitigation controls:

- Security awareness training & phishing simulations
- Multi-Factor Authentication (MFA)
- Advanced email filtering and sandboxing

3) Continuous monitoring:

- Track email activity, login attempts, and unusual access patterns
- Early detection limits damage and response time

4) Relevant compliance standard:

PCI DSS

Requires encryption, access controls, and security awareness training for all organisations handling payment card data.

Summary

Core Concepts:

- Risk = Probability $\times$ Impact
- Threats exploit Vulnerabilities to harm Assets
- CIA Triad: Confidentiality, Integrity, Availability
- Goal: reduce risk, not eliminate it

The Four Phases:

- ① **Identification** – find threats & weaknesses
- ② **Assessment** – analyse likelihood & impact
- ③ **Treatment** – avoid, mitigate, transfer, accept
- ④ **Monitoring** – continuous verification

Key Takeaways

- Use a **risk matrix** to prioritise actions objectively.
- Align risk decisions with **standards** (ISO 27001, NIST, GDPR, PCI DSS).
- Risk management is a **cycle**, not a one-time task.

Thank You

Good luck!

CCY2001 – Introduction to Cybersecurity

Week 11: Risk Management